

FoodMind CI/CD audit and security report — 2026-08-19

Status: evidence-based staging assessment.

Scope: the latest completed release chain, from master commit `1bb8d5141d9e795ba0020c8bfb9d52b5664dfe69` through staging. It assesses controls actually exercised in that release; it is not a production certification or a full penetration test.

Executive conclusion

The release has strong **release-integrity** evidence: source revisions were pinned, all seven images had CycloneDX SBOMs generated and were scanned, published images were ECR-digest-pinned, and the selected manifest was deployed with short-lived GitHub OIDC credentials through AWS Systems Manager. No *fixable Medium/High/Critical* container vulnerability appears in the successful run's seven retained Trivy JSON results. A previous Medium CVE demonstrably stopped publication before deployment.

The staging web surface is **not zero findings**. OWASP ZAP reported one Medium alert and one Low alert. Both are documented policy exceptions, so the workflow passed with known residual risk; it did not pass because ZAP found nothing. The passive unauthenticated scan reached seven URLs, so it cannot prove authenticated authorization, business-logic, or API security.

Finding-source legend

Every finding and non-finding in this document uses one of these labels. They are deliberately not interchangeable.

Marker	Detection source	What it examined in this pipeline
[STATIC]	Static configuration / secret policy	Git-tracked text, Compose rendering and CloudFormation templates. The credential checker is a targeted static secret-pattern check; Compose/IaC policy is static configuration analysis.
[SCA]	Software composition and container vulnerability scan	The operating-system and language dependency inventory inside each built container image, via Trivy.
[DAST]	Dynamic application security test	Live public staging HTTPS responses and URLs discovered by OWASP ZAP; the header gate is a direct dynamic runtime assertion.
[PERF]	Performance / availability test	Live unauthenticated HTTP response time and errors for the two JMeter sampler paths.
[OPS]	Deployment-operability signal	Build, image pull, Compose start, readiness, rollback and SSM execution behaviour. It is not automatically a security vulnerability.

Important: this Infra release pipeline currently has no general source-code SAST engine such as CodeQL or Semgrep. Do not label the Trivy result as SAST: it is **[SCA]**. The only static source checks evidenced here are the targeted credential, Compose, and CloudFormation policy checks marked **[STATIC]**.

Finding register — source made explicit

Marker	Finding or result	Detected by	Decision / current status
[SCA]	CVE-2026-59903 in io.netty:netty-codec-http 4.2.16.Final; fixed versions 4.2.17.Final Or 4.1.137.Final; Medium	Trivy scan of the Backend container in publish run 32123499899	Blocked. Trivy returned non-zero; image publication, deployment, and DAST did not continue.
[DAST]	CSP: Wildcard Directive, Medium, 3 instances	OWASP ZAP passive baseline against staging run 32223405102	Accepted exception. img-src https: remains for external recipe images; recorded in .zap/rules.tsv.
[DAST]	Cross-Origin-Embedder-Policy Header Missing or Invalid, Low, 3 instances	OWASP ZAP passive baseline against staging run 32223405102	Accepted exception. Current cross-origin image compatibility; COOP/CORP remain enforced.
[STATIC]	No configured Compose, tracked-credential, or CloudFormation policy violation	Compose policy, credential-pattern scan, and CloudFormation policy in run 32222627549	Passed within rule scope. This is not a general application-code SAST result.
[SCA]	No fixable Medium/High/Critical issue in seven published images	Trivy JSON artifacts from run 32222796635	Passed within policy scope. Low, Unknown, and unfixed issues are outside the blocking scope.
[PERF]	20 samples, zero errors, p95 1190 ms	JMeter run 32223405055	Passed. Availability evidence only; not a vulnerability result.
[OPS]	EC2 image-pull deployment failure in run 32126338364	SSM/Docker deployment output	Operational failure, not classified as a security finding. The exported log is truncated before a proven root cause.

Historical PPT baseline and cross-repository findings

Scope correction for the “142+ errors” statement

The presentation's 142 figure is **not** a count of every failed CI/CD job across the seven repositories, and it is not a combined SAST/DAST count. It is an historical **[SCA]** aggregate: 142 fixable Medium-or-higher dependency vulnerabilities across six pre-remediation container images (117 Medium, 25 High). Thus every one of those 142 findings, if individually recovered, must be labelled `SCA / Publish staging images / Trivy image scan`, not DAST or SAST.

The retained evidence can verify that aggregate and its remediation claim, but cannot truthfully identify all 142 CVE/package/version records. On 2026-08-19, the accessible `Publish staging images` history contained 94 runs. The three failed runs were checked: run 31716616544 failed before image build/scan, run 31947331992 retained seven Trivy JSON reports with zero vulnerabilities, and run 32123499899 retained the one exact CVE listed in the finding register.

The Git history and retained Actions artifacts do not contain the original six-image JSON/SBOM bundle that produced the 142 count. A report must **not invent 142 CVE names**, image assignments, or scanner stages from a slide total.

To turn the historical aggregate into a 142-row register, recover the original `*-trivy.json` artifacts (or regenerate the same six images from their exact historical source revisions with the same Trivy database/policy). For each row, preserve: image, CVE/advisory ID, package, installed version, fixed version, severity, Trivy target/class, workflow run, and `sca` marker. A modern rescan is useful evidence, but cannot be presented as the original historical output because vulnerability databases and base images change over time.

Individually evidenced historical findings

The following records are individually named in the retained 2026-08-14 security report. They are distinct from the unitemised 142-SCA aggregate above. They show which repository area, stage, and scanner/review detected each issue.

ID	Repository / affected scope	Marker and detection phase	What was detected	Disposition in retained evidence
SEC-001	Infra public entry point	[DAST] ZAP passive baseline	Missing Content-Security-Policy	Closed by Caddy CSP and a runtime header gate.
SEC-002	Infra public entry point	[DAST] ZAP passive baseline	Missing anti-clickjacking protection	Closed with <code>frame-ancestors 'none'</code> and <code>X-Frame-Options: DENY</code> .
SEC-003	Infra public entry point	[DAST] ZAP/header policy review	Incomplete Permissions Policy and cross-orign browser policy	Permissions Policy, COOP and CORP added; COEP remains a documented accepted exception.
SEC-004	All seven repositories	[PROCESS] GitHub branch-protection review	Default branches allowed direct, unprotected changes	Closed by required checks, review, last-push approval, no force-push/deletion policies.
SEC-005	ML	[PROCESS] CI/dependency-definition review	No CI gate or locked dependency definition	Closed by ML CI, lockfile, format/lint/test, <code>pip-audit</code> , licence and Gitleaks gates.
SEC-006	Intelligence	[PROCESS] GitHub required-check review	Two indistinguishable <code>merge-gate</code> contexts	Closed by uniquely named Agent-components and Recommendation-Agent gates.
SEC-007	Infra / RDS	[STATIC] CloudFormation/runtime configuration review	One-day backup retention and no deletion protection	Runtime evidence confirms seven-day retention and deletion protection; final-snapshot lifecycle policy was still pending on the existing stack.
SEC-008	Infra / EC2 and RDS operations	[OPS] infrastructure observability review	Host-local container logs and no baseline EC2/RDS alarms	Logging and four alarms closed; SNS e-mail confirmation remained pending.
SEC-009	Android and Docs workflows	[STATIC] workflow supply-chain review	Third-party Actions referenced with mutable major tags	Closed by full commit-SHA pins in all seven repositories.
SEC-010	Infra public CSP	[DAST] ZAP rule 10055 and CSP review	Arbitrary HTTPS image origins allowed by CSP	Accepted product risk; current ZAP Medium finding is explicitly suppressed by reviewed policy.

`[PROCESS]` is used above for a control/governance defect identified by GitHub configuration review. It is neither a vulnerability scanner result nor a CI test failure. This distinction keeps the report from falsely claiming that ZAP, Trivy, or CodeQL detected a governance issue they did not scan.

What the other repositories actually scan

The workflows below establish *coverage*, not a claim that every listed tool found an issue. A finding is reported only when an artifact or a named historic record above exists. In particular, current **[SAST]** coverage is repository CI, whereas the integrated Infra release gate has only the limited **[STATIC]** checks described earlier.

Repository	CI security stages / inputs	Finding source terminology to use in reports	Retained named historical record(s)
Backend	CodeQL SAST reads Java source; Backend CI checks tracked secrets and proposed dependency changes; published Backend image is scanned by Trivy	CodeQL = [SAST] ; dependency review/Trivy = [SCA] ; secret script = [STATIC]	The exact CVE-2026-59903 release-blocking image finding is Backend [SCA] , not a CodeQL result.
Web	CodeQL SAST reads JavaScript/TypeScript source; Web quality runs its security check; dependency-review examines PR dependency changes; published Web image is scanned by Trivy	[SAST] , [STATIC] , [SCA] respectively	No individually retained Web finding in this evidence set; it must not be assigned an unknown share of the historical 142.
Android	CodeQL SAST reads Kotlin/Java source; dependency-review examines PR dependency changes; Android CI runs build/test/lint	CodeQL = [SAST] ; dependency review = [SCA]	SEC-009 was a [STATIC] workflow-pin finding, not a mobile-code vulnerability. Android is not one of the staging container images.
Intelligence	CodeQL SAST; component/recommendation CI security tests, secret scan, pip-audit, and image Trivy scan for the published agent images	CodeQL = [SAST] ; pip-audit/Trivy = [SCA] ; secrets = [STATIC]	SEC-006 is a [PROCESS] merge-gate identity finding. No individual historic-142 CVE can be allocated without its original JSON.
ML	CodeQL SAST; ML CI runs pip-audit, licence policy and Gitleaks; ML model-package image is scanned by Trivy at release	CodeQL = [SAST] ; pip-audit/Trivy = [SCA] ; Gitleaks = [STATIC]	SEC-005 is a [PROCESS] missing-CI/lockfile finding. No individual historic-142 CVE can be allocated without its original JSON.
Docs	Documentation consistency and real-stack E2E workflow; no application SAST/SCA result is implied by documentation checks	Documentation/E2E result; do not call it SAST/DAST	SEC-009 affected mutable Actions references in Docs workflow.
Infra	Compose/credential/CloudFormation static policy; seven-image SBOM + Trivy; staged header gate + ZAP; deployment checks; JMeter	[STATIC] , [SCA] , [DAST] , [OPS] , [PERF]	SEC-001, SEC-002, SEC-003, SEC-007, SEC-008, and SEC-010; plus the current DAST and Backend-image SCA findings above.

Pipeline inputs, outputs, and enforcement

Workflow	Trigger and input	Security purpose	Output and enforcement	Evidence in assessed release
Compose integration	PR or relevant <code>master</code> change; Infra/submodules, Compose, CloudFormation, release source, example env files	Reject unsafe configuration before build	Rendered Compose, policy/secret/IaC results, stack smoke diagnostics. A failure prevents publication.	Compose, credential, CloudFormation and release-source gates passed; 9-service policy passed.
Publish staging images	Successful same-repository master Compose run; pinned component revisions and Web revision	Supply-chain integrity and vulnerability gate	7 SBOMs, 7 Trivy JSON reports, 7 ECR digests and immutable release manifest. A qualifying Trivy result stops image publication.	All seven scan artifacts are empty within policy; manifest passed structural validation.
Deploy staging	Successful master publication and its manifest	Deploy exact tested bytes with minimum cloud privilege	Validated manifest, optional migration snapshot, SSM output and deployment summary. Failed deploy prevents post-deploy scans.	Runtime, private readiness, public HTTPS, headers and CloudWatch logging passed.
Staging DAST	Successful master deploy and staging HTTPS origin	Verify browser-facing headers and find passive web issues	Header-gate output and ZAP report. Enforced header failure or non-expected ZAP alert fails.	Header gate passed; ZAP returned Medium and Low findings with documented exceptions.
Staging JMeter	Successful master deploy, weekly schedule, or manual HTTPS target	Integrity-check test tool and detect small availability regressions	JTL, HTML dashboard and JSON policy summary.	20 samples, zero errors, p95 1190 ms against <=2000 ms.

Node-level work and scan coverage

The table below answers the audit question “what did each node actually read, scan, and produce?” A passed node means only the stated input and rule set passed; it must not be interpreted as a scan of every repository or every live endpoint.

Workflow / job / step	Files, images, or runtime targets read or scanned	Work performed	Output and stop condition
Compose / changes	The Git diff between the PR base/head or push before/after SHA. It matches paths under <code>.github/workflows/</code> , <code>.env.example</code> , <code>.env.aws.example</code> , <code>.gitmodules</code> , <code>.zap/</code> , <code>Caddyfile</code> , CloudFormation templates, Compose files, <code>releases/</code> , <code>scripts/</code> , and <code>services/</code> .	Decides whether a non-draft PR needs the full stack smoke test.	Boolean <code>compose=true/false</code> ; it is routing logic, not a security scanner.
Compose / validate / Render Compose	<code>compose.yaml</code> plus <code>.env.example</code> , including service definitions and referenced Compose configuration.	<code>docker compose ... config --quiet</code> renders the configuration and rejects invalid interpolation or structure.	No artifact on pass; invalid Compose rendering stops the workflow.
Compose / validate / Compose policy	Source <code>compose.yaml</code> and the rendered JSON of all 9 services.	Rejects <code>privileged: true</code> , host network/PID namespaces, non-loopback host ports, long-running services without health checks, implicit/ <code>latest</code> image tags, and literal sensitive assignments matching <code>PASSWORD</code> , <code>SECRET</code> , <code>TOKEN</code> , or <code>API_KEY</code> .	This run: <code>Compose policy passed for 9 services</code> . Any listed violation fails before image publication.
Compose / validate / credential scan	Every Git-tracked file returned by <code>git ls-files -z</code> that can be decoded as UTF-8 text. It does not inspect ignored files or Git history.	Searches AWS access-key IDs, GitHub/Slack/Stripe token forms and RSA/EC/OpenSSH private-key headers.	This run: <code>Tracked-file credential scan passed</code> . A match prints its file and line then fails.
	<code>scripts/check-aws-env.sh</code> , <code>scripts/check-security-headers.sh</code> , <code>scripts/verify-aws-demo.sh</code> , every	Checks shell syntax; renders AWS	Passed command outputs

Compose / validate / staging contract	<code>scripts/cd/*.sh</code> ; <code>compose.aws-demo.yaml</code> ; <code>compose.aws-cloudwatch-logs.yaml</code> ; <code>cloudformation.aws-demo.yaml</code> ; <code>cloudformation.github-actions-cd.yaml</code> ; <code>cloudformation.observability.yaml</code> ; <code>releases/staging.example.json</code> ; <code>releases/staging-source.json</code> .	Compose with <code>.env.aws.example</code> ; requires every rendered AWS service to use the <code>awslogs</code> driver; runs cfn-lint and policy-as-code; validates example manifest and exact Web SHA format in release source.	include CloudFormation compliance and source-pin success. Any bad shell, rendering, logging, IaC policy, manifest shape, or non-40-character Web revision blocks the chain.
Compose / stack-smoke	<code>compose.yaml</code> , <code>.env.example</code> , and recursively checked-out <code>services/</code> source used to build the integrated local stack.	Builds/starts services, waits up to 240 seconds, calls Backend <code>/actuator/health/readiness</code> , then captures <code>docker compose ps</code> and the last 200 log lines.	<code>ci-evidence/compose-ps.json</code> and <code>compose.log</code> retained 7 days. Failure of build, startup, readiness, or required gate stops publication.
Publish / source resolution	<code>releases/staging-source.json</code> , Infra commit from the successful Compose run, and the exact Web checkout at <code>web_revision</code> .	Requires source JSON keys to be exactly <code>database_migrations</code> , <code>schema_version</code> , and a full 40-character <code>web_revision</code> ; checks the Infra checkout matches the tested SHA.	A selected immutable Infra/Web source revision; mismatch or malformed source stops publishing.
Publish / build, SBOM, Trivy	Seven built images: model-package, inference, recommendation, cooking, chatbot, backend, web. Their inputs are respectively the ML service, Intelligence inference service, Intelligence recommendation/cooking/chatbot agent paths, Backend, and pinned Web Dockerfiles/contexts.	Builds each image, writes one CycloneDX SBOM (<code>*-sbom.cdx.json</code>), then scans each image's OS and language dependency inventory with Trivy.	Seven SBOMs and seven <code>*-trivy.json</code> files, retained 30 days. A fixable Medium/High/Critical CVE exits 1 before that image can be pushed.
Publish / immutable manifest	The ECR digest returned for every successfully pushed image, plus five source SHAs: Infra, ML, Intelligence, Backend, Web.	Requires exactly seven image keys and exactly five source revision keys; each image must be in the expected private ECR repository and pinned by a lowercase 64-hex <code>sha256</code> digest.	<code>release-manifest.json</code> ; any missing service, mutable/wrong registry image, or malformed SHA stops deployment input creation.
Deploy / promotion checks	The <code>staging-release/release-manifest.json</code> artifact from the specific publication run; AWS account/region variables; the tested Infra revision.	Downloads rather than recreates the manifest, validates seven exact ECR digest references and source SHAs, then assumes the limited AWS role by OIDC.	Only a successful master publication may continue. A declared database migration adds a blocking RDS snapshot wait; this release declared none.
Deploy / EC2 SSM release	Base64-transported manifest, checked-out tested Infra revision, remote <code>/opt/foodmind/foodmind-infra/.env.aws</code> , <code>compose.aws-demo.yaml</code> , and optional CloudWatch Compose overlay.	Captures the previous image set, pulls each digest-pinned service with retries, renders Compose, starts with <code>--no-build</code> , and rolls back to the captured images if startup or verification fails.	Current/previous manifest and release environment are mode 600 on the host. Failure triggers rollback and prevents DAST/JMeter.
Deploy / runtime verification	Running services <code>inference</code> , <code>recommendation</code> , <code>cooking</code> , <code>chatbot</code> , <code>backend</code> , <code>web</code> , <code>caddy</code> ; private readiness paths <code>/actuator/health/readiness</code> , <code>/health/ready</code> on ports 8001-8004, Web <code>/healthz</code> , and public <code>https://<staging-origin>/healthz</code> .	Requires all services running; verifies private readiness and Web health; fetches public HTTPS and calls the header checker.	Passed output: containers, private readiness endpoints, Web health, public HTTPS and headers. This is health/config verification, not an authenticated user journey.
DAST / header gate	HTTP response headers from <code>https://<staging-origin></code> in the direct DAST job; the deployment verifier also checks <code>/healthz</code> .	Requires HSTS, CSP baseline and no broad inline style fragment, <code>nosniff</code> , <code>DENY</code> , referrer policy, camera/microphone/geolocation permissions policy, COOP and CORP.	A missing/wrong header or rejected CSP fragment fails before ZAP is considered.
DAST / ZAP passive baseline	Live staging root. This run reported 7 URLs; alert evidence covers <code>/</code> , <code>/robots.txt</code> , <code>/sitemap.xml</code> , <code>/assets/index-DSIICB6m.js</code> , <code>/assets/index-Bcv1W50c.css</code> , and <code>/assets/States-Bqc15_RL.js</code> . Rules come from <code>.zap/rules.tsv</code> .	Pinned ZAP container passively spiders/scans the reachable unauthenticated surface with <code>-a</code> , then applies explicit reviewed suppressions.	ZAP JSON/Markdown/HTML artifact. Non-suppressed configured alerts fail; the listed static files and public paths do not prove coverage of authenticated API routes.

JMeter / target and integrity	<code>tests/performance/staging-smoke.jmx</code> ; JMeter tarball and its pinned SHA-512; HTTPS staging origin.	Rejects a non-HTTPS origin, verifies the test-tool checksum, then runs 5 concurrent users × 2 loops × 2 GET samplers. The two sampled paths are <code>/</code> and <code>/robots.txt</code> , each asserted HTTP 200.	Exactly 20 samples in JTL/HTML/JSON. Any non-zero error rate, sample-count mismatch, or p95 above 2000 ms fails the JMeter run. It does not scan APIs, authenticated flows, Android, or write operations.
-------------------------------	---	---	---

Detailed assessment

Configuration, secret, and cloud policy

The Compose policy rejects privileged containers, host network/PID namespaces, non-loopback published ports, missing health checks on long-running services, mutable or implicit image tags, and literal password/secret/token/API-key values. The passed output is evidence that the submitted rendered configuration did not violate those rules.

The CloudFormation policy requires immutable/encrypted ECR repositories, EC2 IMDSv2, encrypted/non-public/protected RDS with seven-day backups, S3 public-access blocks and retain policies, plus a non-wildcard resource for `secretsmanager:GetSecretValue`. It passed.

The **[STATIC]** tracked-file credential scan also passed. Its scope is intentionally limited to high-confidence AWS access-key IDs, GitHub/Slack/Stripe token patterns, and private-key headers in tracked text files. It is not a full entropy-based secret scan, does not scan Git history or ignored files, and should not be described as complete secret assurance.

Container supply chain

The image publisher uses a Trivy image pinned by digest. For each of model-package, inference, recommendation, cooking, chatbot, backend, and web, it produces a CycloneDX SBOM and runs:

```
--scanners vuln --ignore-unfixed --severity MEDIUM,HIGH,CRITICAL --exit-code 1
```

The correct security statement for the successful release is: **no fixable Medium-or-higher vulnerability was found in the seven produced images at scan time**. It must not be simplified to “there are no CVEs”: Low and Unknown severities are outside the failure threshold, and `--ignore-unfixed` excludes vulnerabilities lacking a known fix. An SBOM supplies inventory and traceability, not proof of absence of vulnerabilities.

The **[SCA]** gate's real blocking behavior is evidenced by run `32123499899`: Trivy found `CVE-2026-59903` in `io.netty:netty-codec-http 4.2.16.Final`, with fixed versions `4.2.17.Final` and `4.1.137.Final`. It was Medium, the command returned non-zero, and no release manifest or deployment followed. This is a concrete discovered-and-blocked security issue.

Provenance, credentials, and deployment

The release source pins components by full Git SHA. The publication manifest replaces mutable tags with seven `repository@sha256:...` image references; the deploy workflow validates that structure before using AWS. This prevents a tag from being retargeted after test and before deployment.

Publish and deploy use GitHub OIDC to obtain short-lived AWS roles, with the expected AWS account checked. The EC2 host receives the selected revision and manifest through SSM, then pulls digest-pinned images instead of rebuilding from a branch. If `database_migrations` is true, an RDS snapshot must finish first. The assessed release declared `false`, so its “snapshot skipped” output is correct and does not claim a snapshot was made.

This proves release provenance and a bounded credential path. It does not prove that every AWS IAM permission is least privilege or that the single-EC2 staging topology is highly available.

DAST and browser headers

The header gate confirmed HSTS, a CSP baseline with no broad inline-style fragment, `nosniff`, `DENY` anti-framing, strict referrer policy, restricted camera/microphone permissions, and same-origin COOP/CORP. These are concrete runtime controls, not just source-code configuration.

The **[DAST]** ZAP report produced these real findings:

Finding	Scanner result	Recorded exception	Residual risk and disposition
<code>CSP: Wildcard Directive</code>	Medium, 3 instances	<code>.zap/rules.tsv</code> accepts <code>img-src https:</code> for external recipe images	The CSP permits images from any HTTPS origin, weakening content-source restriction. Script/style restrictions remain tight. Keep the exception explicit; an image proxy or allowlist would reduce exposure.
<code>Cross-Origin-Embedder-Policy Header Missing or Invalid</code>	Low, 3 instances	Exception records incompatibility with current cross-origin images	The app is not cross-origin isolated. COOP/CORP remain present. Reassess if the media contract supports CORS/CORP.
Base64 disclosure, suspicious comments, cache/modern-app/Sec-Fetch notices	Informational	Reviewed scanner/bundled-asset cases	No exploit was demonstrated by the baseline. Recheck after frontend/bundler changes.

Therefore the accurate conclusion is: **the header and DAST policy gate passed, but its raw report had a Medium and a Low accepted risk**. The baseline is passive and unauthenticated; add authenticated API and role-based tests before making authorization-security claims.

Availability evidence

[PERF] JMeter first verifies the downloaded JMeter SHA-512 and requires an HTTPS origin. Its 20-sample smoke test achieved zero errors and p95 1190 ms under the 2000 ms policy. This supports basic post-deploy availability, but it is neither a stress/DDoS test nor a vulnerability scan. The observed maximum was 2084 ms; that is allowed because policy evaluates p95, not maximum latency.

Residual risks and recommended next evidence

1. Keep both ZAP exceptions visible and reviewed. Replace arbitrary HTTPS image loading with a trusted proxy or allowlist when the product can support it; revisit COEP with a compatible media contract.

2. Add authenticated authorization and object-ownership tests to a security suite. The current unauthenticated seven-URL baseline cannot test those controls.
3. Decide whether Low, Unknown, and unfixed container vulnerabilities should remain report-only or require a time-bounded exception process. The current gate intentionally blocks only fixable Medium-or-higher findings.
4. Add an entropy-capable secret and Git-history scanner if stronger source-secret assurance is required; retain the current fast high-confidence checker.
5. Archive the immutable manifest, SBOMs, Trivy reports, ZAP report, and JMeter output before their 30-day artifact retention ends.

Teacher-ready statement

FoodMind's CI/CD is not merely a green build. It validates Compose and CloudFormation security policies, blocks selected committed credential forms, produces seven SBOMs, blocks fixable Medium-or-higher image CVEs, deploys only digest-pinned images with short-lived OIDC credentials, checks staging HTTPS/security headers, and runs passive DAST plus post-deploy performance policy. In the assessed release the container gate was clean in its configured scope, but ZAP reported one Medium and one Low accepted risk; those exceptions and the unauthenticated DAST scope are explicitly retained as limitations rather than hidden by a passing status.

Appendix A — raw workflow evidence

The following is the original-output appendix for the assessed release. GitHub Actions masks tokens; the public staging origin is replaced with `<staging-origin>`. The links lead authorised project members to complete raw logs and downloadable artifacts.

Release chain and generated evidence

Run time: 2026-08-19 06:15–06:27 UTC (14:15–14:27 Singapore time).

Stage	GitHub run	Result	Produced evidence
Compose integration	32222627549	success	Compose diagnostics, 7-day retention
Publish staging images	32222796635	success	7 CycloneDX SBOMs, 7 Trivy JSON files, immutable manifest, 30-day retention
Deploy staging	32223210273	success	Deployment summary and SSM output
Staging DAST	32223405102	success	ZAP JSON, Markdown and HTML report
Staging JMeter performance	32223405055	success	JTL, HTML dashboard and JSON summary, 30-day retention

Promoted manifest: `staging-1bb8d5141d9e-32222796635-1`; it declares `database_migrations: false` and contains seven ECR image references pinned by `sha256` digest.

[STATIC] Compose integration output

```
Compose policy passed for 9 services.  
Tracked-file credential scan passed.  
CloudFormation compliance gate passed.  
PASS: release manifest staging-20260813-001 is structurally valid and digest-pinned.  
PASS: release source pins Web to d83616f130c02d0c03ef62c7e7dce58f3bdceff7.
```

The same run built the offline stack and executed:

```
curl --fail --silent --show-error http://127.0.0.1:8080/actuator/health/readiness
```

All `validate`, `stack-smoke`, and `compose-gate` jobs concluded `success`.

[SCA] Image publication output

```
Generating SBOM for model-package...  
Scanning model-package for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for inference...  
Scanning inference for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for recommendation...  
Scanning recommendation for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for cooking...  
Scanning cooking for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for chatbot...  
Scanning chatbot for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for backend...  
Scanning backend for fixable Medium-or-higher vulnerabilities...  
Generating SBOM for web...  
Scanning web for fixable Medium-or-higher vulnerabilities...  
PASS: release manifest staging-1bb8d5141d9e-32222796635-1 is structurally valid and  
digest-pinned.  
PASS: release staging-1bb8d5141d9e-32222796635-1 was published with seven immutable ECR  
digests.
```

The seven retained Trivy JSON reports contain no vulnerability items inside the scan's configured scope.

[OPS] Deployment output

```
Release declares no database migrations; snapshot gate skipped.  
PASS: AWS demo environment passed runtime validation.  
CloudWatch container logging is enabled.  
PASS: containers, private readiness endpoints, Web health, public HTTPS, and security  
headers passed.
```

[DAST] DAST output

```
PASS: Strict-Transport-Security
PASS: Content-Security-Policy rejects broad policy fragment
PASS: X-Content-Type-Options
PASS: X-Frame-Options
PASS: Referrer-Policy
PASS: Permissions-Policy
PASS: Cross-Origin-Opener-Policy
PASS: Cross-Origin-Resource-Policy
PASS: staging security header policy is present.
Total of 7 URLs
```

```
High: 0
Medium: 1      CSP: Wildcard Directive (3 instances)
Low: 1         Cross-Origin-Embedder-Policy Header Missing or Invalid (3 instances)
Informational: 9 alert types
```

[PERF] JMeter output

```
apache-jmeter-5.6.3.tgz: OK
summary =      20 in 00:00:05 =    3.8/s Avg:   407 Min:   197 Max:  2084 Err:    0
(0.00%)
{
  "samples": 20,
  "failures": 0,
  "error_rate_percent": 0.0,
  "average_ms": 407.85,
  "min_ms": 197,
  "max_ms": 2084,
  "p95_ms": 1190,
  "policy": {
    "expected_samples": 20,
    "max_error_rate_percent": 0.0,
    "max_p95_ms": 2000
  }
}
JMeter gate passed.
```

[SCA] Proven release-blocking scan output

[Publish staging images run 32123499899](#) failed before its release manifest could be uploaded. Its retained Trivy artifact contains:

```
backend-trivy.json  CVE-2026-59903  io.netty:netty-codec-http
installed: 4.2.16.Final
fixed:     4.2.17.Final, 4.1.137.Final
severity:  MEDIUM
```

The associated command ended with `Process completed with exit code 1`; image publication stopped and the dependent deployment and DAST workflows were skipped.

[OPS] Separate operational failure

[Deploy staging run 32126338364](#) failed while pulling digest-pinned images through Systems Manager. Its exported GitHub output is truncated during Docker pull progress and ends with `Process completed with exit code 1`; it is recorded as an availability/release-operability incident, not a proven security finding.

Appendix B — retained historical source output and evidence boundary

The following statements are reproduced from the project-controlled presentation script and historical security report. They are source evidence for the historical count, **not** a substitute for the missing 142-row Trivy output.

Historical SCA aggregate (presentation script)

```
This is a historical remediation result, not a permanent zero-risk claim.
The baseline found 142 fixable Medium-or-higher findings in six images.
After OS and dependency remediation and runtime reduction, the declared policy
reported zero fixable Medium-or-higher findings across the seven-release-image scan.
Unfixed findings and new vulnerabilities still require ongoing monitoring.
```

Historical DAST counts (security report)

```
Initial OWASP ZAP passive baseline: 0 High, 2 Medium, 4 Low, 4 Informational.
Post-fix OWASP ZAP passive baseline: 0 High, 1 accepted Medium,
1 accepted Low, 9 Informational.
```

The source report identifies the remaining Medium as the CSP wildcard for arbitrary HTTPS recipe images and the Low as the COEP exception. The ten individually named historical security/process findings are transcribed with their true detection source in the register above.

Artifact-recovery result (2026-08-19)

```
Publish staging images runs accessible: 94
Failed run 31716616544: failed before image build/scan.
Failed run 31947331992: seven retained SBOM + Trivy JSON pairs; 0 vulnerability items.
Failed run 32123499899: Backend Trivy found CVE-2026-59903 (Medium) and returned exit code
1.
Original six-image 142-finding Trivy/SBOM artifact: not retained in accessible Actions
history or Git history.
```

This is the exact evidence boundary for the PPT claim. Until the original artifact is recovered, the defensible presentation wording is: **“historical baseline: 142 fixable Medium-or-higher SCA findings across six images; the individual vulnerability records are not retained in the current evidence archive.”**